



한국개미집공단 수행 결과 보고서
인프라 보안 12기 가디언즈

2026. 08.

1 프로젝트 개요

[표 1] 프로젝트 소개

구분	내용
프로젝트명	한국개미집공단 인프라 구축 프로젝트
대표 서비스	실시간 주식 모의투자 웹 플랫폼
수행 과정	인프라 보안 12기
수행 기간	2026.08.03.(월) ~ 2026.08.25.(화) / 총 3주
수행 인원	총 5명 (피준원, 윤탁준, 장우영, 장원영, 함도율)

1.1. 배경

최근 개인투자자의 시장 참여가 확대되면서 고위험·뇌동매매로 인한 재정적 손실위험이 커지고 있다. 이에 실전 투자 이전에 안전하게 투자 습관을 훈련할 수 있는 체험형 모의투자 플랫폼의 인프라 필요성이 대두되었으며, 본 프로젝트는 이러한 모의투자 공공기관인 한국개미집공단의 서비스 인프라를 설계 및 구축하고 보안을 검증하는 것을 목표로 수행되었다.

1.2. 수행 범위

■ **인프라 설계 및 구축:** 네트워크 아키텍처 설계, 총 8대의 물리적 서버 (게이트웨이, 웹, DB, API 연동, 로그) 구축
■ **보안 정책 수립:** 접근제어(방화벽), 로그인·세션·계정 보안, 데이터 보호, WAF/IDS-IPS, 로그 수집·보관 정책 수립
■ **보안 검증:** 실제 공격 시나리오 기반 모의침투 테스트 및 방화벽 룰셋 차단 테스트 수행
■ **결과물 정리:** 인프라 구축보고서·수행 결과보고서 작성 및 발표자료(PPT, 웹 사이트 시행 영상) 제작

2 프로젝트 목적 및 목표

2.1. 프로젝트 목적

■ **자산 보호:** 고위험·뇌동매매로 인한 개인투자자의 재정적 손실을 선제적으로 예방하고 개인투자자의 자산을 보호

■ **건전한 투자문화 조성:** 체험형 모의투자 플랫폼을 제공하여 올바른 투자 습관을 형성하고 건전한 자본시장 문화를 조성

2.2. 프로젝트 목표

■ **서비스 단위 인프라 분리:** 게이트웨이, 웹, DB, API 연동, 로그 수집을 8대 서버로 역할 분리하여 구축

■ **Zero Trust 기반 방화벽 정책:** Any-to-Any 규칙을 비활성화하고 사전 정의된 통신만 허용하는 화이트리스트 기반 접근 제어 구현

■ **다층 보안 관제 체계:** WAF(ModSecurity+OWASP CRS), IDS/IPS(Suricata), SIEM(Graylog+OpenSearch)을 연계한 탐지·차단·로그 수집 체계 구축

■**실증 기반 보안 검증:** 설계한 보안 통제가 실제로 동작하는지 공격 시뮬레이션과 방화벽 룰셋 테스트로 직접 검증

3 프로젝트 오버뷰

3.1. 팀 구성 및 역할

[표 2] 수행 인력

구분	담당 업무	세부 수행 업무
피준원	인프라·네트워크 총괄 및 웹 서버 구축	전체 네트워크 아키텍처 및 방화벽(NAT/ACL) 설계, OPNsense 방화벽 및 WireGuard VPN 게이트웨이 구축, Nginx 및 PHP-FPM 기반 Web Server 구축
윤탁준	DB 서버 설계 및 네이버 API 구축	MariaDB 설계 및 DB Server 구축 (데이터 암호화/무결성), 계정 인증 정책(회원가입/로그인) 설계, 네이버 뉴스 검색 API 수집 서버 구축
장우영	중앙 로그 서버 및 카카오 API 구축	Graylog·OpenSearch 기반 중앙 로그 수집 서버 구축, 카카오 소셜 로그인 연동을 위한 API 서버 구축, Nginx 프록시 환경 구성 및 ModSecurity WAF 연동
장원영	실시간 시세 연동 서버 구축	한국투자증권(KIS) 시세·시장데이터 수집 API 서버 구축, 실시간 시세 워커 수집기 구축, 큐 파이프라인 구성 및 응답속도 최적화
함도율	보안 관제 총괄 및 구글 API 구축	[2주차 복귀 후 수행] Suricata IDS/IPS 및 Graylog SIEM 보안 관제 환경 구축, 구글 소셜 로그인 연동을 위한 API 서버 구축, STRIDE 위협 모델링, 모의 침투 테스트 및 보고서 총괄

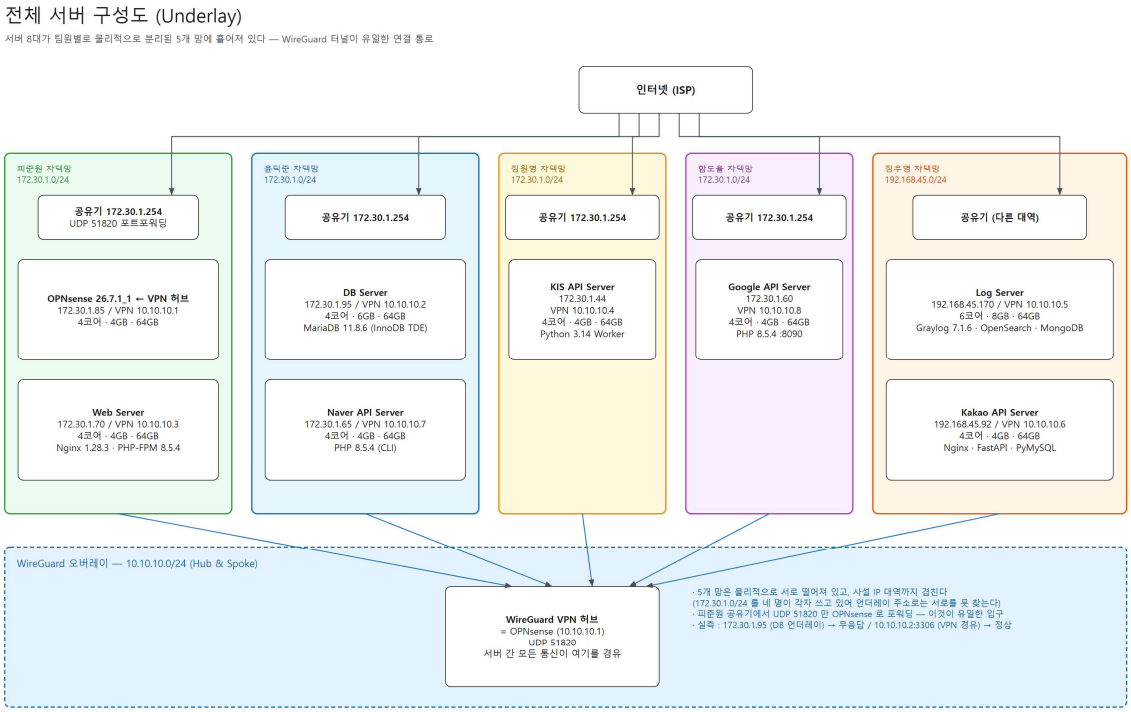
3.2. 수행 일정

[표 3] 수행 일정

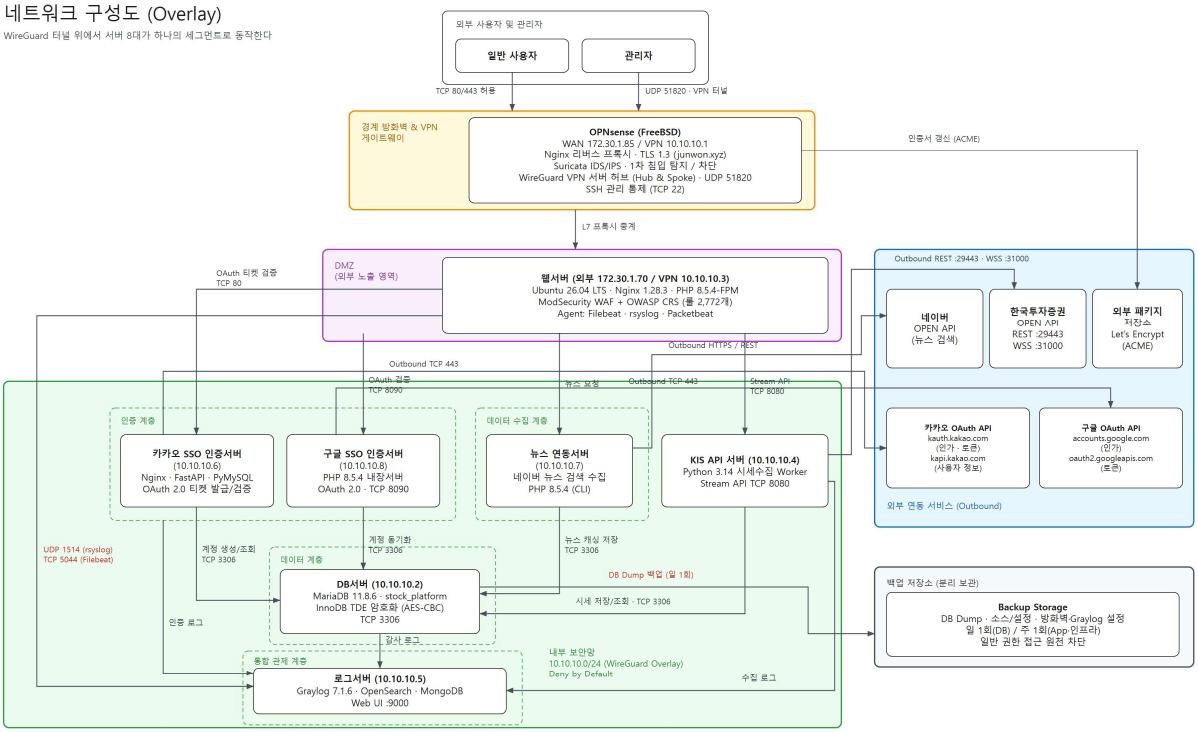
구분	일정	세부 수행 내용
정보 수집 및 사전 준비	2026.08.03.(월) ~ 2026.08.05.(수)	주식 시장 동향 및 오픈 API 규제 조사
		서비스 플랫폼 사전 조사
		R&R, WBS, Ground Rule 작성
인프라 구축 기획	2026.08.06.(목) ~ 2026.08.09.(일)	OPNsense 게이트웨이 및 WireGuard VPN 네트워크 다이어그램 작성
		LEMP 스택 및 Graylog SIEM 관제 설계
		DB 스키마 및 계정 인증 정책 수립
인프라 구축 수행	2026.08.10.(월) ~ 2026.08.16.(일)	OPNsense 게이트웨이 및 WireGuard VPN 구축
		Nginx 웹 서버 및 PHP-FPM 연동, ModSecurity WAF 설정
		MariaDB 데이터베이스 구축 및 PDO 연동
		Filebeat/Packetbeat 수집기 및 Graylog SIEM 연동
보고서 및 발표자료 작성	2026.08.13.(목) ~ 2026.08.25.(화)	모의 침투 테스트(SQL Injection, XSS, SSH 무차별 대입) 수행
		Graylog 차단/탐지 로그 수집
		발표자료(PPTX) 제작 및 발표 녹화 영상(MP4) 촬영

3.3. 시스템 아키텍처 개요

■ **서버 구성:** OPNsense, Web Server, DB Server, Log Server, Naver/Kakao/Google/KIS API Server로 총 8대로 역할 분리



■ **네트워크 구역:** DMZ(Web Server), 외부망(OPNsense 게이트웨이), 내부망(10.10.10.0/24, WireGuard 오버레이), 관리망, 로그망으로 구분

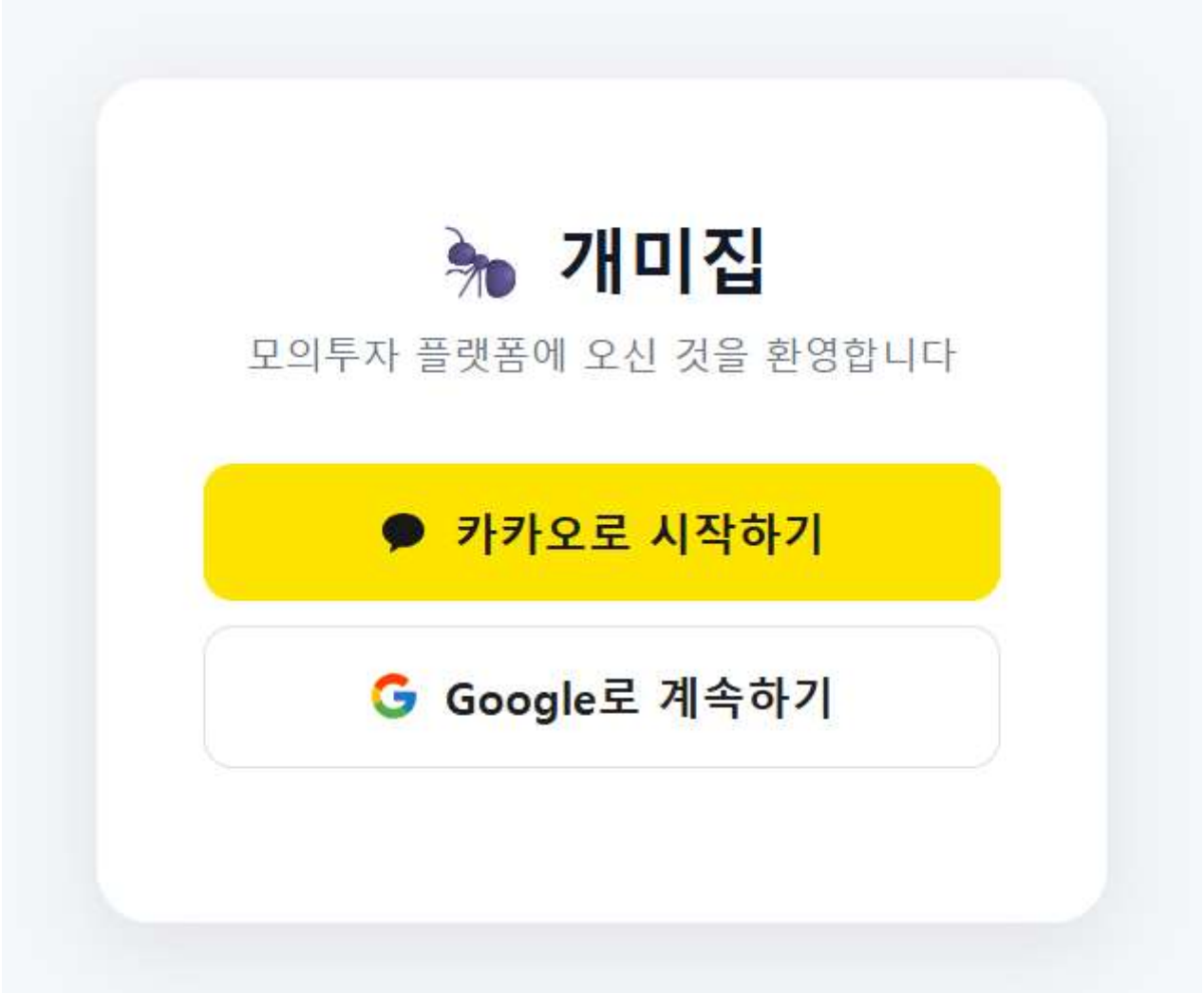


■ **보안 스택:** OPNsense Firewall, WireGuard VPN, Nginx + ModSecurity(OWASP CRS) WAF, Suricata IDS/IPS, Graylog + OpenSearch SIEM 등

[표 4] 네트워크 보안 장비

구분	주요 역할	작동 방식
OPNsense Firewall	네트워크 접근 제어 및 방화벽	외부/내부 트래픽을 정책 기반으로 검사하고 허용되지 않은 접속 차단, NAT 및 네트워크 보호 수행
WireGuard VPN	서버 간 암호화 통신	VPN 터널을 생성하여 서로 다른 네트워크의 서버 간 안전한 통신 제공
WAF (Web Application Firewall)	웹 공격 차단	HTTP/HTTPS 요청을 분석하여 SQL Injection, XSS 등 웹 공격 탐지 및 차단
IDS/IPS	침입 탐지 및 차단	네트워크 패킷을 분석하여 이상 행위와 공격 패턴을 탐지하고 필요 시 차단
Graylog + OpenSearch	보안 로그 수집 및 분석	Web/API/DB/Firewall 로그를 수집하고 이상 접근 및 보안 이벤트 분석

■ **인증 체계:** 카카오/구글 소셜 로그인(OAuth 2.0), 자체 아이디/비밀번호 회원가입 미제공

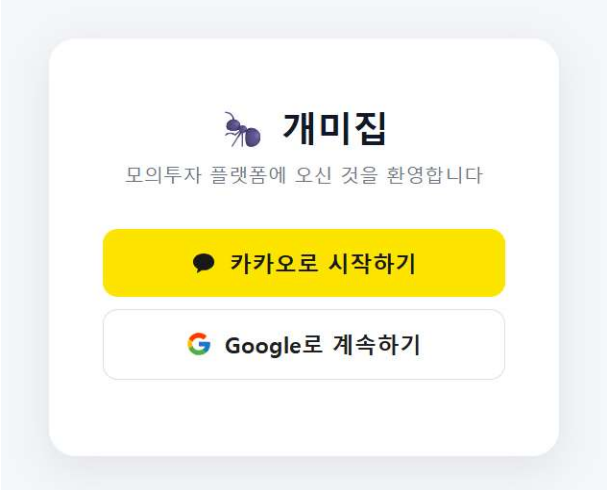


4 산출물

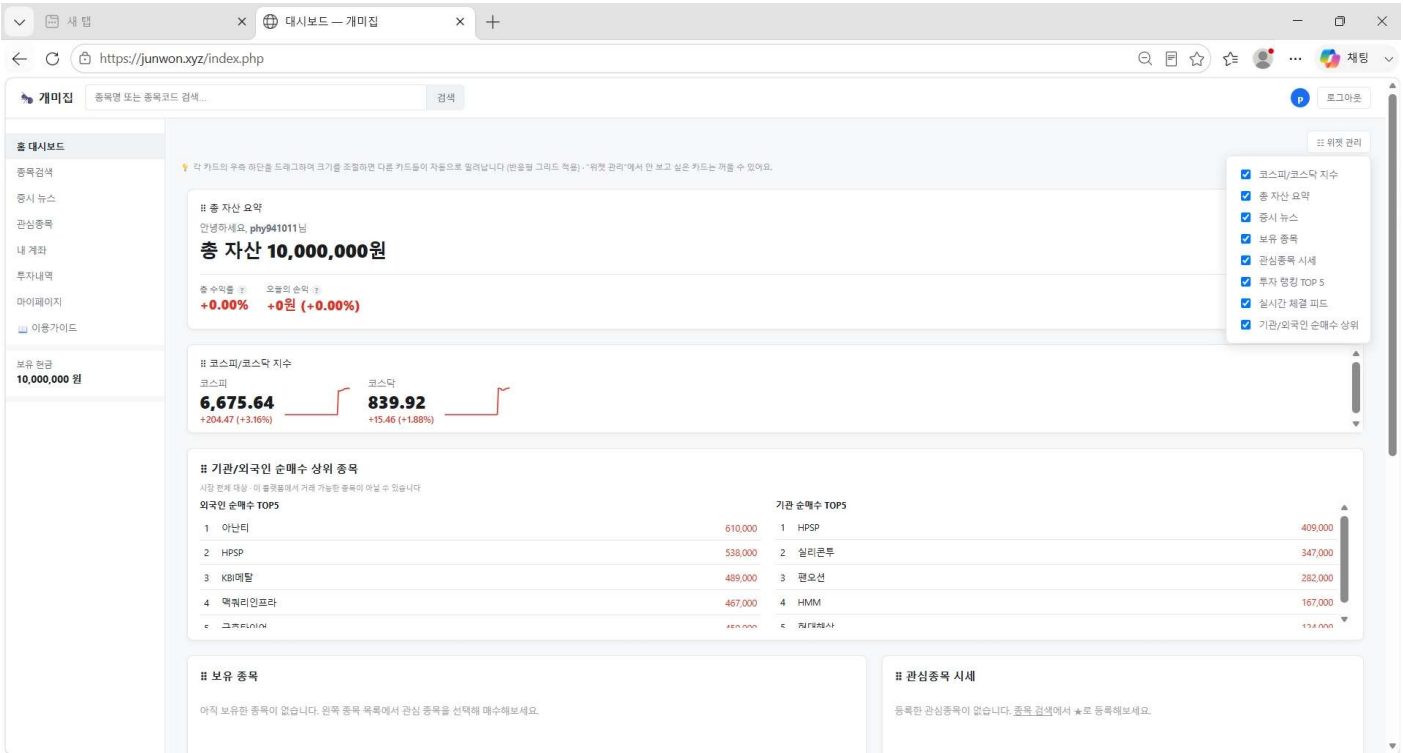
4.1. 웹 서비스

실시간 주식 모의투자 웹 사이트(junwon.xyz)를 구축하였다. 주요 기능은 다음과 같다.

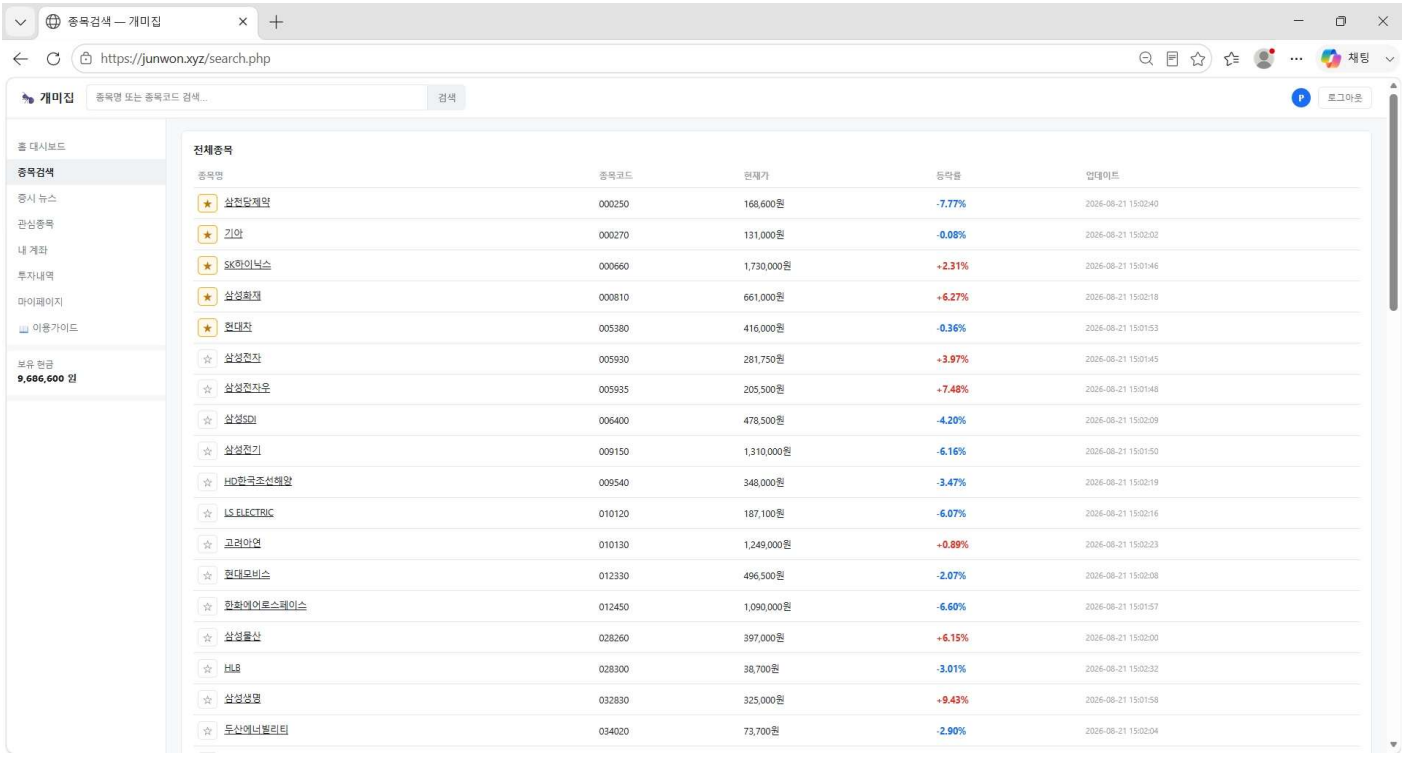
■ **로그인 화면:** 카카오/구글 계정 로그인 가능.



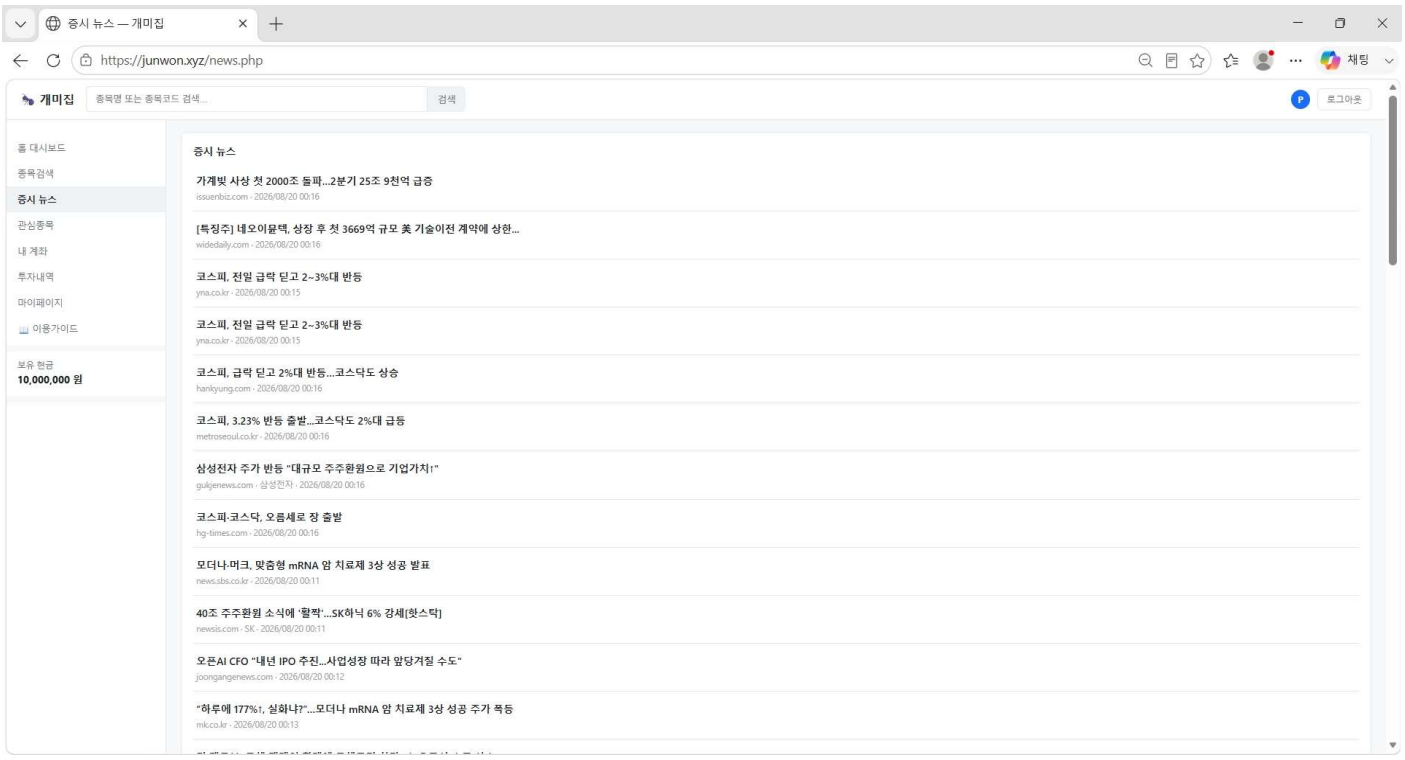
■ **홈 대시보드:** 로그인 후 첫 화면. 총자산·수익률·오늘의 손익을 한눈에 보고, 코스피/코스닥 지수, 증시 뉴스, 보유·관심종목, 투자랭킹 TOP5, 실시간 체결 피드, 기관/외국인 순매수 상위를 위젯 등이 위치. 우측 「위젯 관리」로 원하는 카드만 켜고, 카드 크기도 드래그로 조절하는 커스터마이즈 가능.



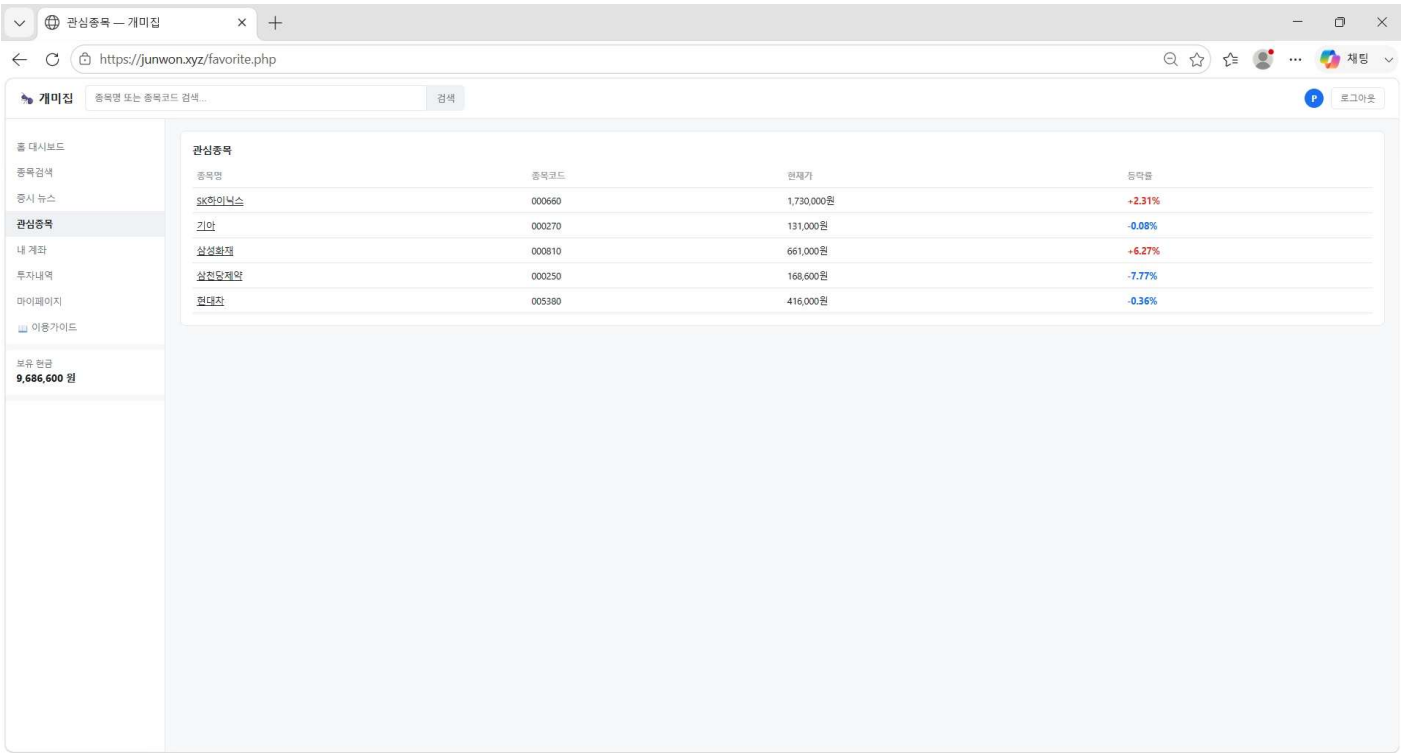
■ **종목 검색:** 검색창에 종목명·코드를 넣어 찾거나, 전체 종목이 현재가·업데이트 시각과 함께 나열. 종목명 옆에 위치한 ☆로 관심종목 채택 가능.



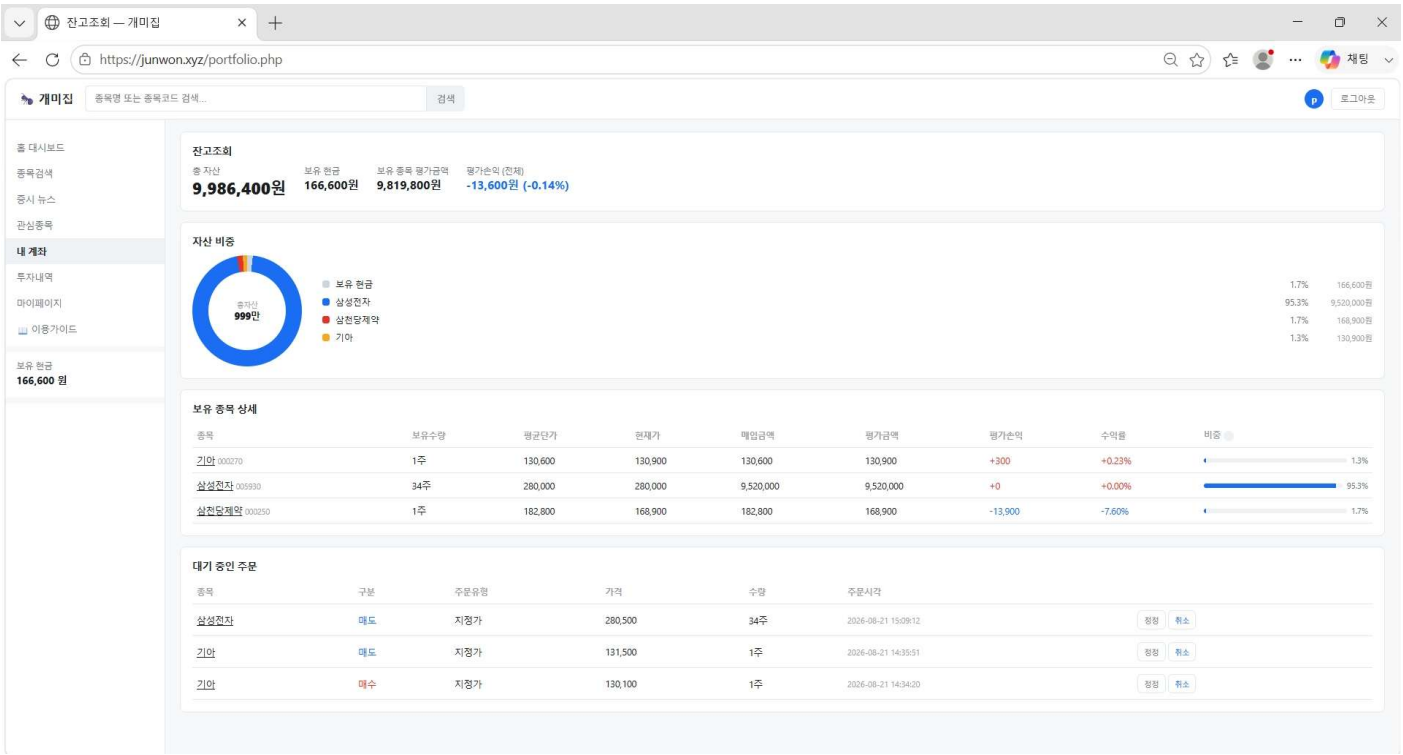
■ **증시 뉴스:** 네이버 뉴스 API를 통한 증시·경제 뉴스를 출처·업데이트 시각과 함께 나열. 더블 클릭시 원문 기사로 이동.



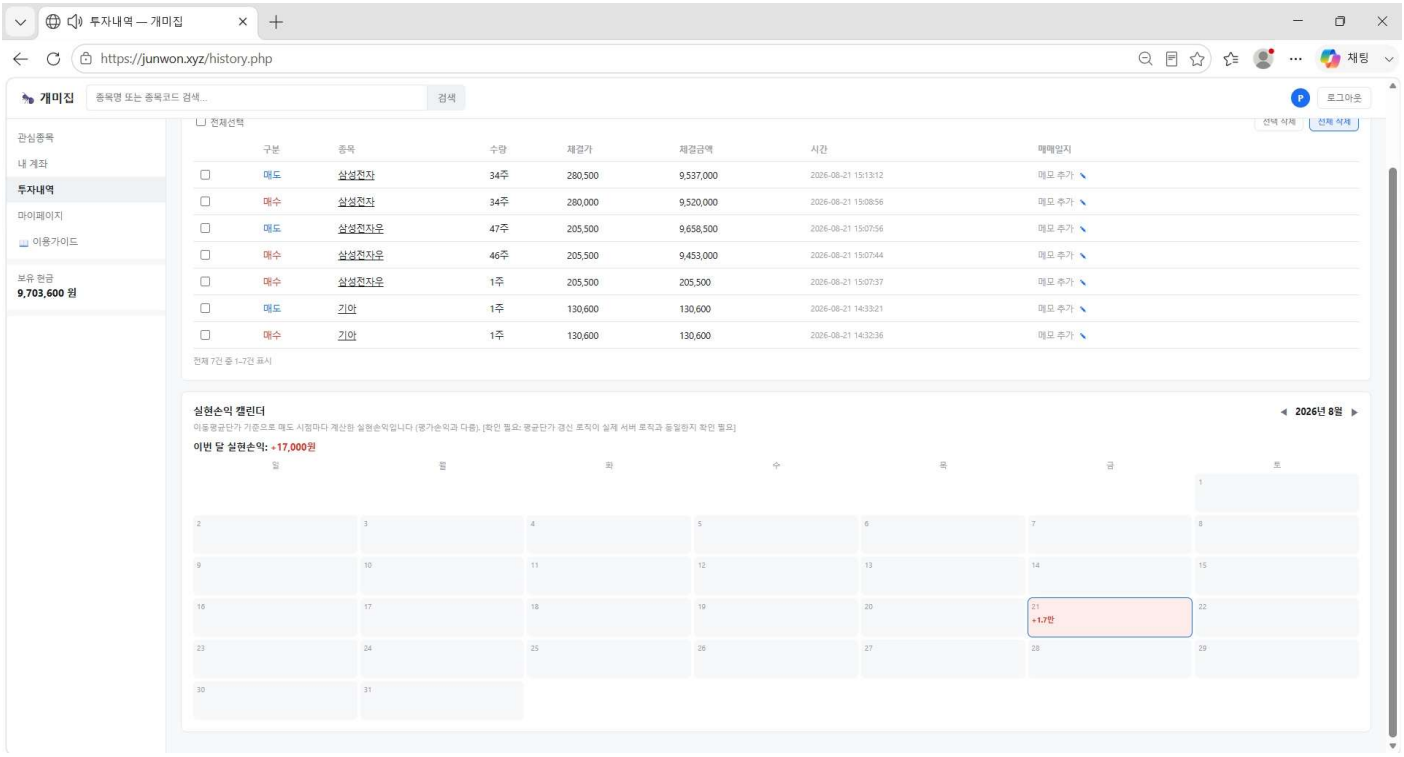
■ **관심종목:** 종목 검색에서 ☆로 담아둔 종목을 현재가와 등락률과 함께 모아보는 워치리스트.



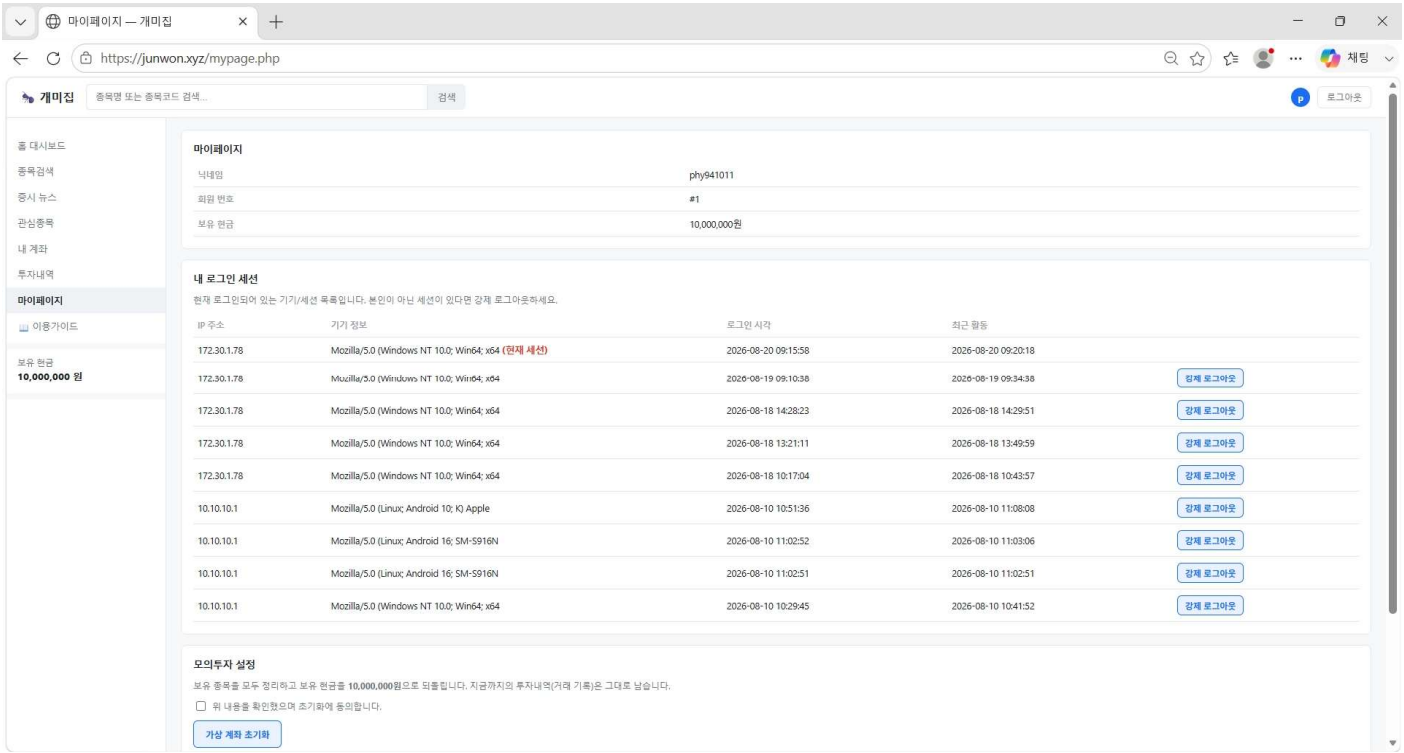
■ **내 계좌:** 총자산·보유현금·평가금액·평가손익과 자산 비중 도넛차트, 보유종목 상세, 대기 중인 주문 목록 등을 볼 수 있는 포트폴리오 화면.



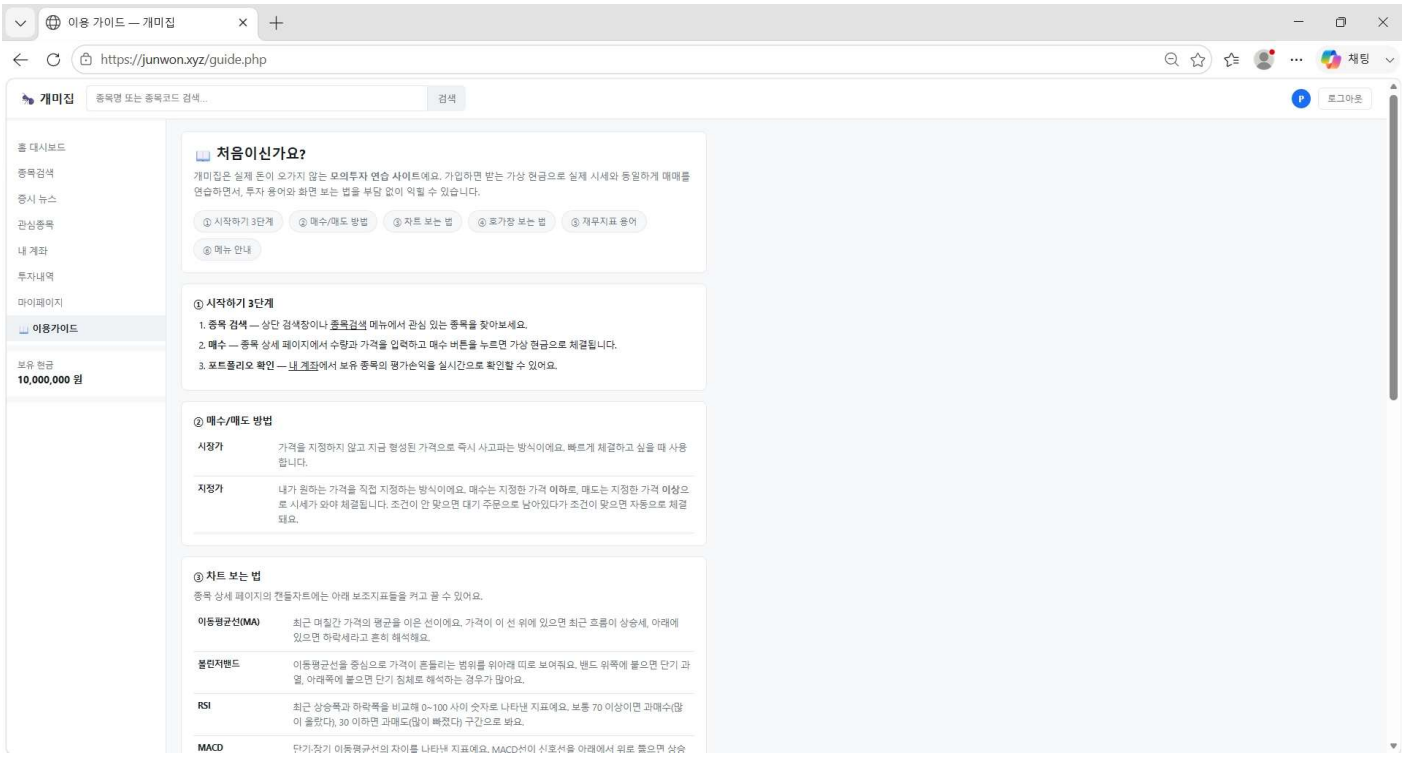
■ **투자내역:** 이용자가 설정한 기간 별 투자내역 확인. 매매일지 작성 가능. 실현 손익 캘린더를 통한 날짜 및 월별 손익을 한눈에 파악 가능.



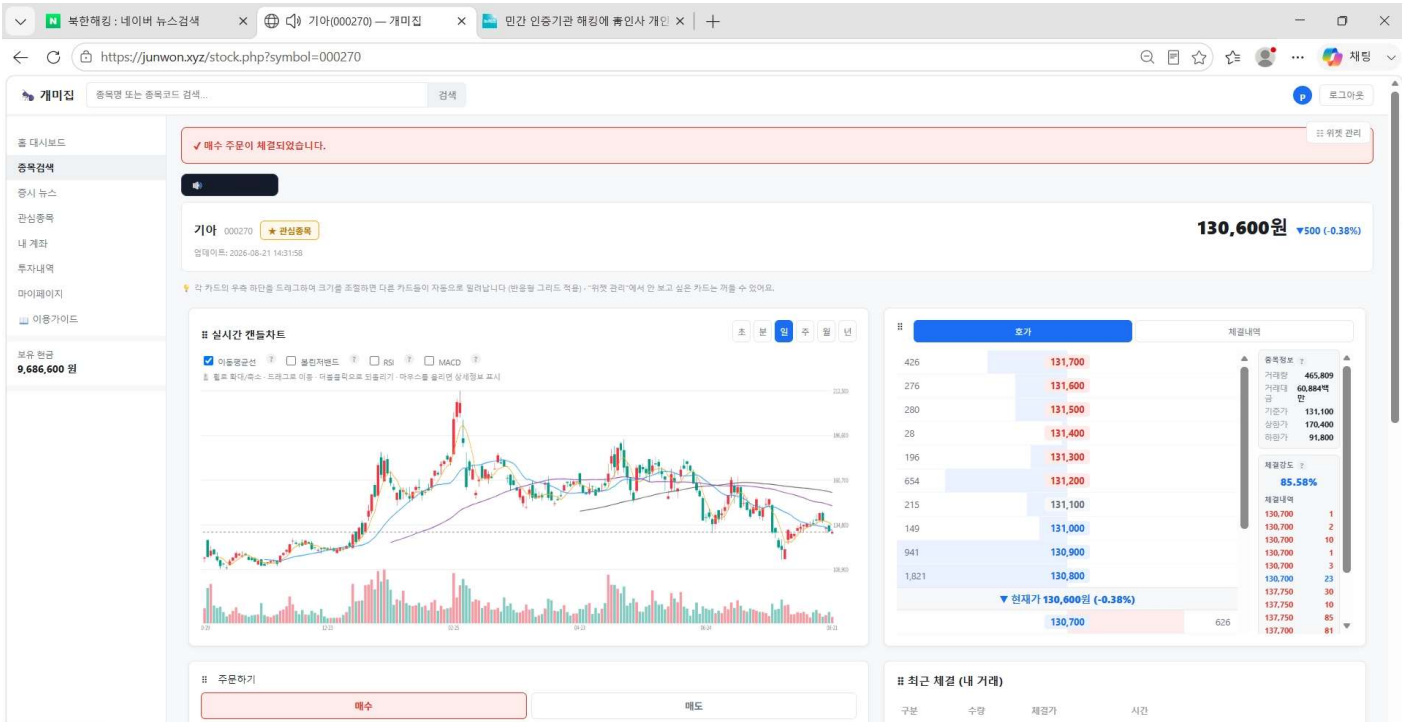
■ **마이페이지:** 닉네임·회원번호·보유현금 확인. 내 로그인 세션 목록(IP·기기·로그인 시각)을 보고 다른 기기 강제 로그아웃 가능. 가상 계좌 초기화(보유종목 정리·현금 1,000만원 복구, 거래기록은 보존) 가능.



■ **이용가이드:** 주식 초보자나 웹사이트 입문 사용자를 위한 안내 페이지. 기본적인 모의 주식 거래를 위한 기본 사항, 매수/매도(시장가·지정가) 방법, 차트 보조지표(MA·볼린저·RSI·MACD) 보는 방법, 호가창·재무지표 용어 등이 설명. 개인 투자자의 역량 강화를 목적으로 한 교육 플랫폼으로서, 투자 용어와 개념을 체계적으로 학습할 수 있는 환경을 제공.



■ **매수/매도 주문:** 실시간 주가가 반영된 호가창에서 시장가·지정가 중 주문 유형을 선택하고 수량을 입력해 체결하는 화면. 지정가 주문은 조건이 맞을 때까지 대기 주문으로 남아 있다가 자동 체결되며, 체결 결과는 내 계좌·투자내역에 즉시 반영.

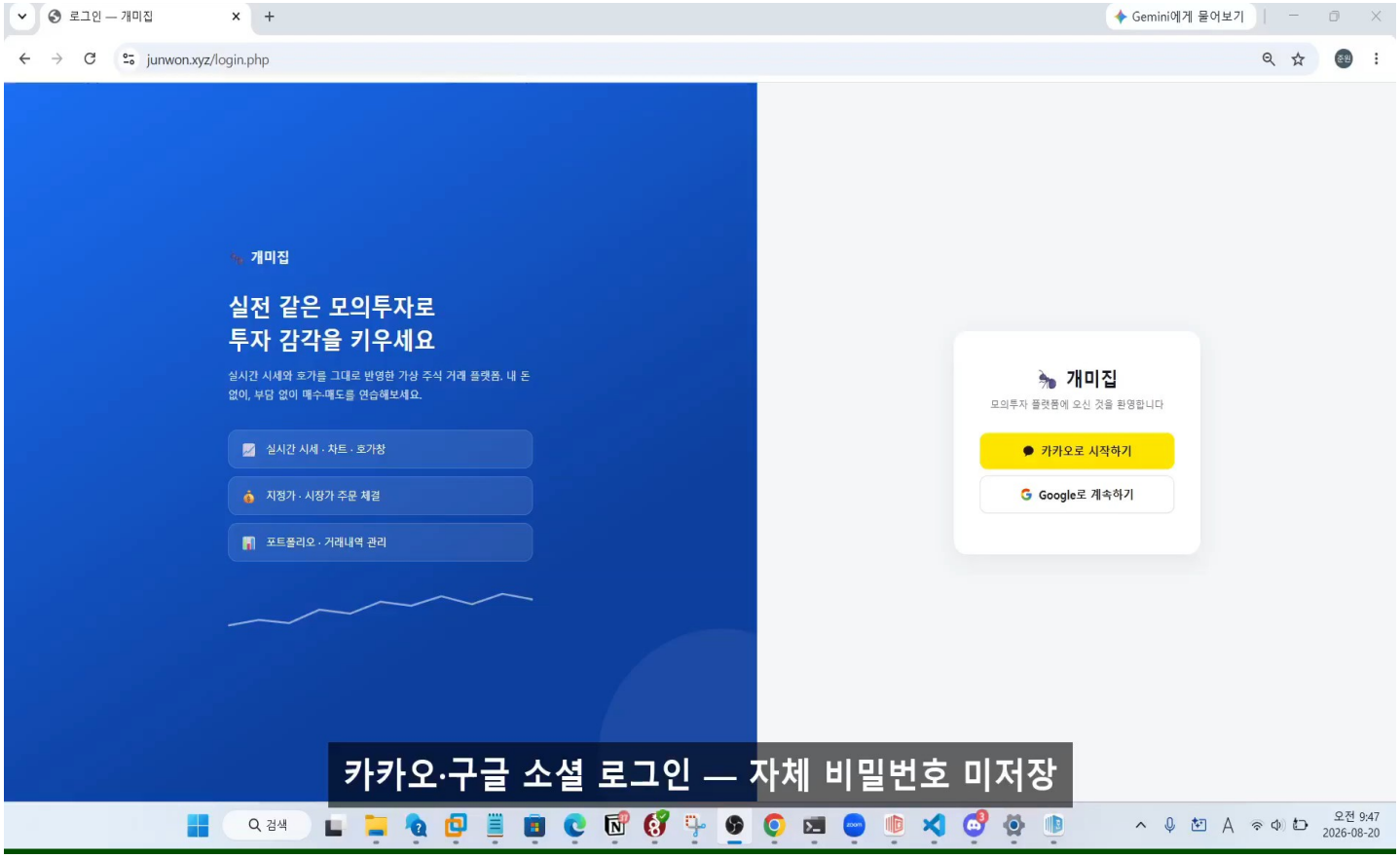


4.2. 결과 보고서

■ **인프라 구축 보고서:** 네트워크·서버 구성, 보안 정책, 모의침투 테스트 결과 등 기술 상세를 담은 문서
■ **수행 결과 보고서(본 문서):** 프로젝트 목적·수행 과정·산출물·성과·영상 등을 종합한 보고서

4.3. 영상

본 프로젝트의 산출물인 실시간 주식 모의투자 웹 사이트(junwon.xyz)의 주요 기능을 시연하는 발표 녹화 영상을 제작하였다. 영상은 카카오·구글 소셜 로그인부터 실시간 시세·차트·호가 조회, 지정가·시장가 주문 체결, 포트폴리오·거래내역 관리에 이르는 전체 사용자 흐름을 시연한다.



5 성과 및 기대효과

5.1. 산출물 구현 설명

[표 5] 산출물 구현 설명

영역	구현 결과
네트워크/게이트웨이	OPNsense 방화벽 및 WireGuard VPN(Hub&Spoke) 구축, 사용자 → 내부망 전 구간 Default Deny 방화벽 정책 적용
웹/애플리케이션	Nginx + PHP-FPM 웹 서비스, ModSecurity(OWASP CRS) WAF 연동으로 SQL 인젝션·XSS 탐지 및 차단(HTTP 403) 구현
데이터베이스	MariaDB 구축 및 계정·거래내역·잔고 테이블 암호화, 계정별 최소 권한 원칙 적용
보안 관제	Suricata IDS/IPS 및 Graylog/OpenSearch SIEM 연동, 방화벽·WAF·IDS 로그 중앙 수집 체계 구축
모의침투 테스트	Brute Force(SSH), CSRF, 매수/매도 동시요청 Race Condition, IDOR, WAF SQLi/XSS, CSV 수식 인젝션, 미인증 API 접근 등 7개의 시나리오 수행 및 각 시나리오에서 설계한 통제가 정상 동작함을 확인
방화벽 룰셋 테스트	외부망에서 Web/DB/Log/Kakao·Google·KIS·Naver API 서버로의 직접 접근을 각각 시도하여 Default Deny 정책의 동작을 검증

5.2. 종합적 평가 및 시사점

5.2.1. 잘된 점

■ **역할 기반 분업 체계:** 팀원별 담당 서버·영역을 명확히 나누어 병렬로 구축을 진행함으로써 3주라는 짧은 기간 내 8대 서버 구성을 완료

■ **설계-구현-검증 연결:** 방화벽 규칙·보안 정책을 표로 문서화하는데 그치지 않고, 실제 공격 시뮬레이션과 방화벽 로그로 정책이 의도대로 동작하는지 직접 확인

5.2.2. 한계 및 보완이 필요한 점

■ **분산 환경에서의 네트워크 설계 문서화:** 팀원 각자의 물리적으로 분리된 네트워크 환경에 서버가 분산된 구조였던 만큼, 이 구조가 문서 전반에 걸쳐 일관되고 명확하게 설명되도록 다듬는 작업이 추가로 필요

■ **일부 서비스의 운영 등급 스택:** OAuth 연동 서버 간에도 프로덕션에 적합한 스택(Nginx/FastAPI 등)과 개발용 스택이 혼재되어 있어, 향후 실제 운영을 가정한다면 일관된 스택으로 정리가 필요

5.2.3. 시사점

본 프로젝트를 통해 방화벽·WAF·IDS/IPS·SIEM을 연계한 다층 보안 아키텍처를 처음부터 끝까지 설계 및 구축하고, 그 결과를 실제 공격 재현으로 검증하는 전 과정을 경험하였다. 이는 이론적인 보안 정책 수립을 넘어, 실무에서 요구되는 '설계한 통제가 실제로 방어되는가'를 증명하는 실증적 보안 검증 역량을 기르는 계기가 되었다.